

```
500/udp open isakmp
NAC Address: 00:1B:D5:54:4D:E4 (Cisco Systems)
```

```
Nmap done: 1 IP address (1 host up) scanned in 0.17 seconds
```

The options used were `-sU` for UDP scan, and `-p` to only scan the specified port. The scan output shows the ISAKMP port (UDP port 500) open.

Ike-scan

Ike-scan is a simple but powerful command-line tool that is used to find and fingerprint VPN gateways. It sends specially crafted IKE packets to target gateways and enlists any IKE responses that are received. By default, Ike-scan works in main mode, and sends a packet to the gateway with an ISAKMP header and a single proposal with eight transforms inside it. Each transform contains a number of attributes like DES or 3DES as the encryption algorithm, SHA or MD5 as the integrity algorithm, a pre-shared key as the authentication type, Diffie-Hellman 1 or 2 as the key distribution algorithm and 28800 seconds as the lifetime.

Initial IPsec VPN discovery with Ike-scan is as shown below:

```
root@bt:~# ike-scan -M 172.16.21.200
Starting ike-scan 1.9 with 1 hosts (http://www.nta-monitor.com/tools/ike-scan/)
172.16.21.200 Main Mode Handshake returned
HDR=(CKY-R=d90bf054d6b76401)
SA=(Enc=3DES Hash=SHA1 Group=2:modp1024 Auth=PSK
LifeTime=Seconds LifeDuration=28800)
VID=4048b7d56ebce88525e7de7f06dc2d3c0000000 (IKE
Fragmentation)

Ending ike-scan 1.9: 1 hosts scanned in 0.015 seconds (65.58
hosts/sec). 1 returned handshake; 0 returned notify
```

The `-M` shows each payload in a line, so that the output will be neat and easy to understand. The output can be any of the following:

- **0 returned handshake; 0 returned notify:** This means the target is not an IPsec gateway.
 - **1 returned handshake; 0 returned notify:** This means the target is configured for IPsec and is willing to perform IKE negotiation, and either one or more of the transforms you are acceptable.
 - **0 returned handshake; 1 returned notify:** VPN gateways respond with a notify message when none of the transforms are acceptable (though some gateways do not, in which case further analysis and a revised proposal should be tried).
- In the example shown, the VPN gateway replies

with one returned handshake and the acceptable transform set has these parameters:

```
Enc=3DES Hash=SHA1 Group=2:modp1024 Auth=PSK LifeType=Seconds
LifeDuration=28800
```

Custom transform sets can be tried against the target with the `--trans` switch:

```
--trans={1=1,2=2,3=1,4=2}
```

...where 1=Encryption Algorithm, 2=Hash Algorithm, 3=Authentication Method, 4=Group Description, and 5=Group Type. Kindly refer to RFC 2409 Appendix A for a complete understanding of transform set values (<http://www.ietf.org/rfc/rfc2409.txt>). There are a number of other tools like *ipsectrace*, *ipsecsniff*, etc, available for IPsec scanning, but undoubtedly Ike-scan is one of the best and a frequently updated tool.

Vulnerability assessment tools like Nessus, Nexpose, etc, can be used to identify the vulnerabilities of VPN implementations. A full security audit on the target gateway with such types of tools will generate a detailed report with all identified problems and the mitigation steps available.

Fingerprinting the VPN gateway for guessing implementation

Vendor identification and software detection of the gateway is achieved in the fingerprinting phase. To proceed with fingerprinting, you need to get a handshake message from the gateway, containing the acceptable transform set details. As the default IKE doesn't offer reliability for transmitted packets, VPN gateway vendors will use their own back-off algorithm to deal with the 'lost in transit' traffic.

The attacker sends an initial IKE proposal to the VPN gateway with an acceptable transform set. The attacker doesn't reply and carefully analyses the server response messages for some time. (The default time Ike-scan waits for back-off fingerprinting is 60 seconds.) By analysing the time difference between the received messages from the server and the matching response pattern, the pen tester can successfully fingerprint the VPN gateway vendor.

Some VPN servers will use the optional Vendor ID (VID) payload with IKE to carry some proprietary extensions. This will really make fingerprinting easy for the attacker. Most of the time, VID is a hashed text string. Ike-scan can use the `--vendor` switch to add the VID payload to outbound packets. The received VID payload can be displayed by Ike-scan directly, as shown below:

```
root@bt:~# ike-scan -M --showbackoff 172.16.21.200
```